

Two hospitals, one model, zero shared records

We build a federated model that predicts readmission in 30 days. We attack it with the strongest known membership inference attack. Then we measure the cost of each defence, in accuracy and in patients exposed. Each number on these pages is the mean of **3 independent runs** over **6,000 patients** and 13 clinical features.

0.585

The LiRA attack AUC against the model that we trained without care. This model is also the **least accurate** model. Poor training causes a loss of privacy and a loss of accuracy.

0.771

The federated DP model at $\epsilon=3$. It reaches **98.3%** of the highest score that is possible (0.784). It costs 0.6% of the AUC.

0.506

The attack AUC against that model, with the strongest published attack. This is the mean of 3 runs, with an SD of 0.007. The attack is no better than a guess, in each run.

The law makes federation necessary, not optional

Federal Law No. 2 of 2019 (UAE Health Data Law). You must not store, process or transfer UAE health data outside the State. Ministerial Resolution No. 51 of 2021 gives a small number of exceptions. Our design does not use an exception. No data crosses a border.

PDPL Art. 20 (Federal Decree-Law 45/2021). You must encrypt the data and remove the names. But this does not limit what an attacker can learn from the behaviour of the model. Pages 2 and 3 show that an attacker can use this gap.

Why membership is important. An attacker finds the record of a named person in the training data. The attacker then knows that this person was a patient at a known hospital in a known period. The prediction is not the sensitive part. The presence of the record is.

Hospital A

3,000 patients · 16.3% readmitted



Local DP-SGD

per-sample clipping + calibrated noise, *before* anything leaves



Hospital B

3,000 patients · 40.2% readmitted

Three architecture decisions a reviewer should check

- **The server is outside the trust boundary.** Each hospital adds the noise before it sends an update. An attacker who controls the server learns no more than the ϵ bound permits.
- **We use parallel composition, not sequential composition.** Each patient is at only one hospital. The two clients use different data. Thus the system ϵ is the **maximum** of the two values, not the sum.
- **We do not save a fitted scaler.** The features use published clinical ranges, not values from our own patients. A `StandardScaler` that you fit on training data holds the mean and the variance of those patients. The deployed file then releases them, and no ϵ counts this loss. This change also removed a pickle file, which is an unsafe format to load.
- **The two clients have different data.** Their readmission rates differ by 2.5 times. This is the usual condition in a real federation.

Seven attacks, two threat models, one correct metric

T1 Label-agnostic adversary

This attacker sees only the output probability of the model. It knows no other data about the patient.

`confidence`, `neg_entropy`

T2 Label-aware adversary

This attacker also knows if the patient was readmitted, for example from an insurance claim. This attacker is stronger. We keep the two types apart, because a mix of the two gives a result that is too high.

`yeom_neg_loss`, `class_calibrated_loss`, `learned_ensemble`, `lira`

All attacks against the weak model, from the 2017 method to the newest

ATTACK	T	AUC	TPR@0.1%FPR	TPR@1%FPR
<code>class_calibrated_loss</code>	T2	0.586 ± 0.001	0.139%	1.11%
<code>lira</code>	T2	0.585 ± 0.003	0.181%	1.89%
<code>learned_ensemble</code>	T2	0.583 ± 0.004	0.139%	1.07%
<code>yeom_neg_loss</code>	T2	0.577 ± 0.006	0.097%	1.04%
<code>confidence</code>	T1	0.497 ± 0.009	0.042%	0.68%

We do not show `neg_entropy` and `modified_entropy`. For a task with two outcomes, they put the records in the same order as `confidence` and `yeom_neg_loss`. Their curves are the same. To show them again would count one attack two times.

Why we use TPR at a low FPR, not accuracy or AUC

An attack can be only 51% accurate on average. But if that attack identifies 0.2% of the patients almost surely, this is a data breach. An average value hides the result that hurts a person. We report both values. We rank the attacks on the value that this number of patients can measure.

Why LiRA is the important attack

A global threshold asks one question: is this loss very low? That question mixes two different causes. The model can *memorise* a record, or the record can be *easy*. Most records are easy, thus they hide the records that the model memorised.

LiRA trains 32 shadow models for each model. It learns the score of each record with that record in the training data, and without it. Then it does a likelihood-ratio test. LiRA calibrates **for each patient**, thus only true memorisation gives a high score.

What we give the attacker, and what we did not test

The attacker can only send queries to the model. It has no weights, no gradients, and no control of the training. For LiRA, the attacker also has a sample of similar data and enough compute to train shadow models. This is the usual assumption.

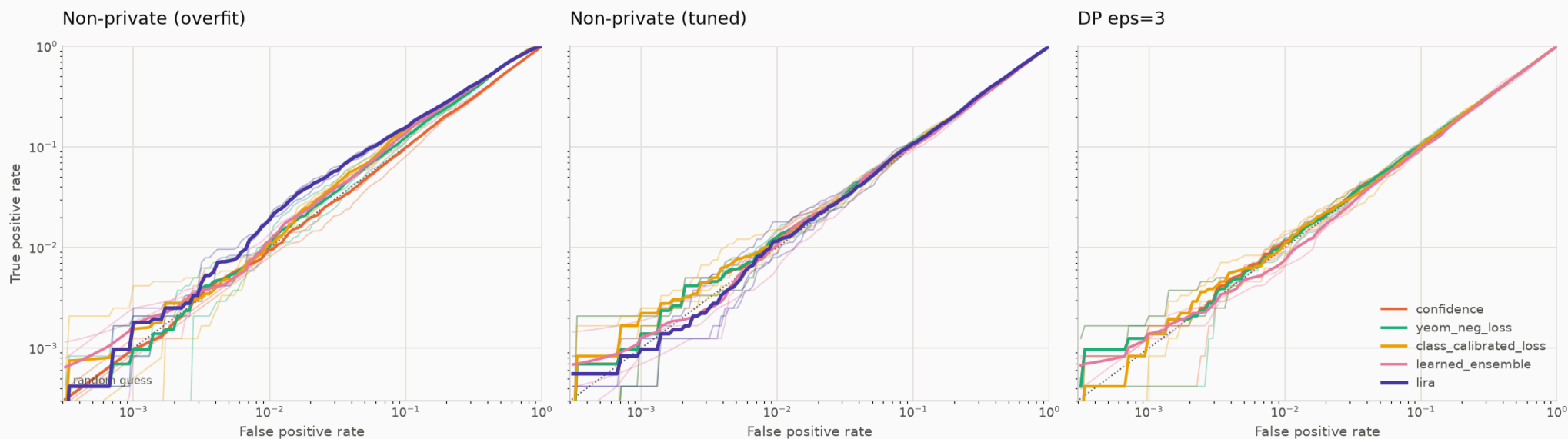
Out of scope: model extraction, attribute inference, poisoning, and white-box gradient attacks. Each one needs its own test. We do not make a claim that we did not measure.

Measurement discipline

- We **cross-fit** the attacks. The attacker that scores a record used different data for its calibration.
- Each value has a **stratified bootstrap 95% interval** (400 resamples). Thus "no better than a guess" is a measured result.
- We train each model **3 times, on 3 different splits**. Each value is the mean of the runs. Each error bar is the spread between the runs. No result depends on one split.
- With 3,000 non-members, the smallest false-alarm rate that we can measure is **0.03%**. This is three times smaller than in Stage 2.

Three times more patients makes the leak smaller. It does not stop it.

Attack ROC on log-log axes, 3 independent runs per curve



The ROC curve on log-log axes. Each curve shows three runs as thin lines, with their mean as a thick line. The corner at the bottom left is the important area, because the attack identifies patients there almost surely. Linear axes hide that area. Against the weak model, LiRA (violet) is above all the threshold attacks. Against the tuned model and the DP models, no attack goes above the diagonal, in any run.

0.586

The attack AUC on the careless model. This is the mean of 3 runs, with an SD of 0.0014. With 800 training records the value was 0.655. With 2,400 records it is **0.586**. More data causes less memorisation. But the leak is still 62 SDs above chance.

The average AUC hides the attack that you must prevent

The first four attacks are within 0.009 AUC of each other. On that measure they look the same.

At a false-alarm rate of 1%, LiRA finds **1.89%** of the training patients. The best threshold attack finds **1.11%**. LiRA finds **1.7×** more people, with the same number of false alarms.

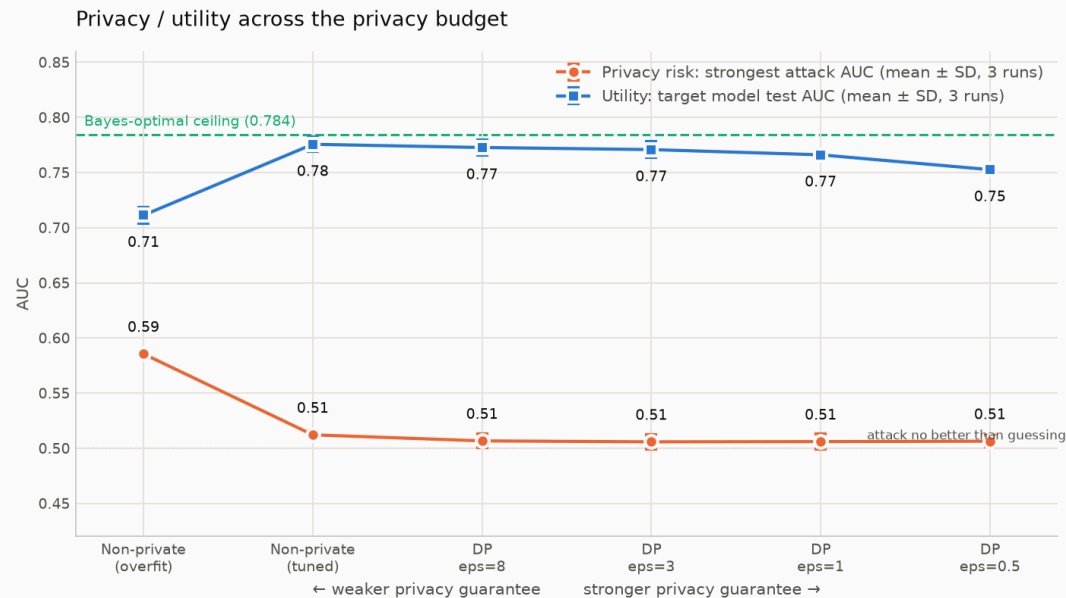
This difference is the reason to calibrate for each record. The measure that most teams report cannot show it.

The attack is at its limit. It is not weak.

A loss-threshold attack can only divide the records that the model got right from the records that it got wrong. Thus its AUC cannot go above $0.5 + \text{accuracy_gap}/2 = \mathbf{0.564}$, at an average gap of 0.127.

We measured `yeom_neg_loss` at **0.577**. It is at its limit, thus it uses all of the available signal. LiRA is better at a low FPR because it does not use only that signal.

The cost of each defence, and proof that our DP is correct



We measure the utility against the **highest possible score of 0.784**. We calculate that score from the known process that made the data. Thus nobody can say that our non-private model is weak. The error bars show ± 1 SD over 3 runs. They are smaller than the markers. That is the result, not a fault in the chart.

TARGET MODEL	TEST AUC	% CEIL	ATTACK AUC	E ACCT.	E EMP.
Plain (overfit)	0.711 $\pm$ 0.007	90.7%	0.586 $\pm$ 0.001	none	2.36
Plain (tuned)	0.776 $\pm$ 0.007	98.9%	0.512 $\pm$ 0.003	none	0.01
DP $\epsilon=8$	0.773 $\pm$ 0.007	98.5%	0.507 $\pm$ 0.006	7.99	0.00
DP $\epsilon=3$	0.771 $\pm$ 0.007	98.3%	0.506 $\pm$ 0.007	2.99	0.00
DP $\epsilon=1$	0.766 $\pm$ 0.005	97.7%	0.506 $\pm$ 0.007	0.99	0.00
DP $\epsilon=0.5$	0.753 $\pm$ 0.005	95.9%	0.506 $\pm$ 0.005	0.50	0.00

We audited our own DP code

To use a DP library is not proof that the DP works. We convert the result of each attack into a **measured lower limit on ϵ** . We use the Kairouz privacy region and the safe end of a Clopper-Pearson interval. Thus the limit is correct at 95% confidence.

This test can only show a fault. It cannot show that the limit is tight.

One run at $n=2,400$ gives a wide limit. Thus $\epsilon_{\text{emp}} \ll \epsilon_{\text{acct}}$ proves nothing about the accounting. But $\epsilon_{\text{emp}} > \epsilon_{\text{acct}}$ would prove that the code is wrong. This does not occur in any run. The test finds the *unprotected* model at $\epsilon \geq 2.36$, thus the test can find a real fault.

The careless model is worse in both ways

The overfit model leaks the most. It also predicts the worst, at 90.7% of the highest possible score. Privacy and accuracy are not opposite goals. Only the careless model loses both.

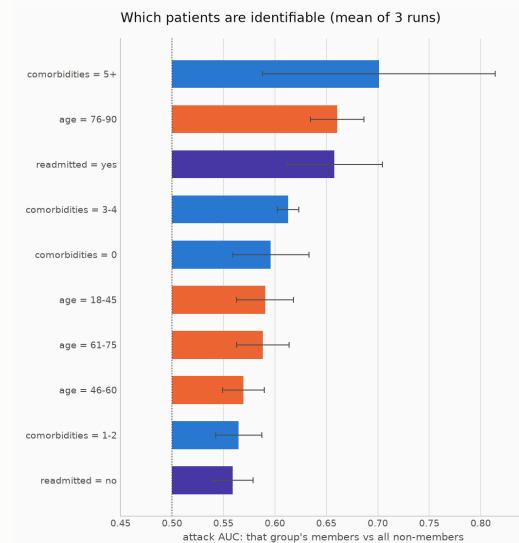
Careful training is not a guarantee

LiRA still scores 0.512 against the tuned model. That is above chance in all 3 runs. Careful training makes the leak small. It does not remove the leak. Only DP brings the attack down to chance level, and only DP gives a limit that also covers a new attack.

We change one variable at a time

Each model uses the same split, the same scaling, the same class weights, the same architecture and the same seed. If they did not, this curve would measure the settings, not the privacy.

The leak affects the most ill patients



GROUP	N	ATTACK AUC
comorbidities = 5+	95	0.701 ± 0.113
age = 76-90	158	0.661 ± 0.026
readmitted = yes	678	0.658 ± 0.046
comorbidities = 1-2	1298	0.565 ± 0.022
readmitted = no	1722	0.559 ± 0.020

The attack identifies patients with **5+ comorbidities** at **0.701 ± 0.113**. For readmitted = no the value is 0.559 ± 0.020. This order occurs in all 3 runs. But that group has only 95 members in each run. Thus we report a **direction, not an exact value**.

The model memorises the records that are not usual, because it cannot generalise them. Thus the patients who can lose the most also have the highest risk.

The weaker attacks **cannot show this**. They show the same risk for all groups. Only calibration for each record makes the difference visible. One global ϵ gives these patients too little protection.

Recommendation: use the $\epsilon=3$ federated model

It gives a test AUC of 0.771, which is 98.3% of the highest possible score. Each hospital gets a formal (2.99, 1e-5) guarantee. Under the strongest published attack, the result is no better than a guess.

Do not use $\epsilon=0.5$. It costs a further 2.4% of the AUC. It does not make the attack weaker, because both models are already at chance. To lose accuracy for privacy that you cannot measure is not correct for a clinical system.

What we did not prove

- The data is synthetic and logistic. There are still only two clients.
- The 3 seeds measure the spread between runs. They do not measure the spread between different groups of patients, because the patients do not change.
- The ϵ audit gives a wide lower limit from one run.
- We do not use secure aggregation. The privacy claim does not need it, because each update is already private. But a production system must add it.
- **We did not compare DP against careful training directly.** The gap between them is small. We can show only that the strongest attack stays above chance against careful training, and does not against DP.

Reproducible, and checked

`python run_all.py` makes every number and figure on these pages again, from the start. This is all 3 runs, in about 25 minutes. `src/build_deck.py` builds this deck from `results/`, thus no page can disagree with the data. We set every seed and pin each package version, because a new Opacus release can report a different ϵ for the same noise value. We run 13 checks on the files. For example: no validation record enters the attack set, both models use one definition of membership, and no two seeds use the same training set.